



ReadyPackets Security & SDLC Assessment

Evidence-based application, API, webhook, infrastructure, and production-readiness review

Prepared for ReadyPackets administrators

Assessment date: August 13, 2026 · Classification: Confidential operational assessment

Contents

1	Executive conclusion	1
1.1	Assessment scope and method	1
2	Security posture observed	2
2.1	Strengths already present	2
2.2	OWASP Top 10 and API alignment	2
3	Prioritized remediation plan	3
3.1	P0 – complete before unrestricted public launch	3
3.2	P1 – complete during controlled launch readiness	4
3.3	P2 and P3 – resilience and maturity	4
4	API and webhook security requirements	4
5	Secure SDLC operating model	5
6	Decision gates and next actions	5
7	References	5

1 Executive conclusion

ReadyPackets has a comparatively strong **application-level foundation** for a self-hosted customer portal. The reviewed production configuration uses HTTPS, nginx reverse proxying to a loopback-only application, a restrictive nonce-based Content Security Policy, origin-bound CSRF validation, role-scoped MFA policy, encrypted sensitive fields with blind indexes, audit logging, rate controls, IP controls, and a current production dependency audit with no reported production-package advisories. The application also has protected backup, restore, and update-control designs rather than exposing shell-level actions to a browser process.

However, this review is a source, configuration, and non-invasive production-control assessment—not an external penetration test, code-signing assessment, or forensic incident review. The most material remediation before an unrestricted public launch is **outbound webhook SSRF prevention**. The current webhook endpoint configuration accepts any syntactically valid URL and sends server-side requests to it. An administrator or compromised administrator could target localhost, private ranges, cloud metadata services, or internal services. This maps directly to OWASP API7:2023 Server Side Request Forgery. [2]

> Recommendation: Treat this report as a **conditional go-live assessment**. Do not declare the platform fully launch-ready until the P0 controls in the remediation register are complete, independently tested in staging, and approved by the accountable owner.

1.1 Assessment scope and method

The review examined the current private repository, Node/Express/tRPC/Drizzle/MySQL implementation, configured production service topology, nginx/TLS/firewall posture, application header/CSRF/session controls, authenticated administration surfaces, webhook implementation, protected backup/update helpers, installation scripts, and existing verification artifacts. The report also considers the OWASP Top 10:2025, OWASP API Security Top 10:2023, OWASP Developer Guide, and OWASP SAMM as control baselines. [1] [2] [3] [4]

No destructive testing, credential attacks, denial-of-service testing, payment testing, account takeover exercise, or production restore were performed. Evidence is time-bound to the assessment date; a secure posture requires continuous verification.

In scope	Application source, deployment scripts, production health/header/TLS observations, infrastructure hardening, API/webhook design, backup/update controls, dependency audit.
Out of scope	External penetration testing, Cloudflare account settings review, third-party SaaS configurations, payment-provider controls, customer endpoint hygiene, and attack simulation.

, [Rating method], [P0 blocks unrestricted launch; P1 should be completed before or immediately after controlled launch; P2 is planned hardening; P3 is operational maturity.]))

2 Security posture observed

2.1 Strengths already present

Control area	Assessment	Evidence and practical value
Identity and sessions	Strong	Role-aware procedures, administrator MFA enforcement, session revocation, password/MFA rotation, and captured source/device metadata on new session rotations reduce account takeover and support investigations.

, [Browser protections], [Strong], [Nonce CSP uses strict-dynamic, removes inline script/event execution, limits frames and connections, restricts browser features, and uses frame-ancestors 'none'. Origin + double-submit + session-bound CSRF controls protect unsafe cookie-authenticated requests.]), [Data protection], [Strong], [Sensitive fields use AES-256-GCM encryption and HMAC-style blind indexing. Production database binding is loopback-only and the application listens only on 127.0.0.1 behind nginx.]), [Authorization], [Generally strong], [Customer, staff, and administrator procedures, object access helpers, paid-order gating, workspace permissions, and typed destructive confirmations are evidence of deliberate authorization design.]), [Operations], [Improving], [Protected local backup/restore controls, root-owned socket daemons, rollback snapshots, timer-based backups, and security event/alert review reduce operational blast radius.]), [Supply-chain point-in-time check], [Positive], [The production dependency audit returned 0 known advisories across 334 production/optional dependencies on the assessment date. This is a point-in-time indicator, not an ongoing software-composition program.)))

2.2 OWASP Top 10 and API alignment

OWASP Top 10:2025 identifies broken access control, misconfiguration, supply-chain failures, cryptographic failures, injection, insecure design, authentication failures, integrity failures, logging/alerting failures, and exceptional-condition handling as major web risks. [1] OWASP API Security 2023 emphasizes object/function authorization, authentication, resource consumption, sensitive business-flow abuse, SSRF, misconfiguration, inventory, and unsafe third-party API use. [2]

Framework category	Posture	Assessment
A01 / API1 & API5 access control	Partially evidenced	The architecture has role-specific procedures, ownership checks, customer sharing RBAC, and payment gates. Retain authorization tests for every ID-bearing endpoint and introduce automated IDOR/BOLA regression cases.

, [A02/API8 misconfiguration], [Partially evidenced], [TLS, HSTS, headers, firewall, and systemd hardening are deliberate. The certificate path is currently Let's Encrypt-specific, and Cloudflare mode/Origin Pull configuration still needs a governed console/install path.]), [A03 supply chain], [Partial], [A clean point-in-time audit is positive, but no repository CI workflow was found in the inspected inventory. Add lockfile policy, SBOM, dependency scanning, secret scanning, and signed/reviewed release controls.]), [A04 cryptographic failures], [Generally strong], [Field encryption, keyed lookup, TLS, and secret handling

are present. Add formal key inventory, recovery escrow, rotation runbooks, and automated certificate-expiry monitoring.)), [A05 injection], [Partially evidenced], [Typed tRPC inputs and ORM usage reduce common injection risk. Complete SAST and targeted SQLi/template/command-injection tests; keep root-helper arguments fixed and allowlisted.]), [A06 insecure design], [Partial], [The system contains many strong security mechanisms, but a documented threat model and abuse-case acceptance criteria are not yet evident.]), [A07/API2 authentication], [Generally strong], [MFA, SSO policy, session controls, rate limits, and account lifecycle controls are substantial. Complete external authentication-flow tests and recovery-path review.]), [A08 integrity], [Partial], [Signed Stripe webhooks and encrypted configuration exist; upgrade/backup operations are guarded. Add verified build provenance, signed artifact policy, and immutable release attestation.]), [A09 logging/alerting], [Improving], [Security Centre, activity replay, session grid, source investigation, and alert lifecycle exist. Add retention, alert routing, monitoring ownership, and a testable incident-response runbook.]), [A10/API4 resource consumption], [Partial], [Rate limits and upload quotas exist. Add capacity thresholds, queue controls, large-export/download review, and load testing before marketing traffic.]), [API7 SSRF], [Needs remediation], [Webhook endpoint URLs are validated only as URLs before fetch. They require protocol, DNS, IP-range, redirect, egress, and revalidation controls.)))

3 Prioritized remediation plan

3.1 P0 — complete before unrestricted public launch

Priority	Finding	Risk and recommended remediation	Acceptance evidence
P0-1	Outbound webhook SSRF	Webhook administration currently accepts any URL shaped as a URL and posts server-side payloads to it. Restrict to HTTPS; resolve DNS immediately before connect; deny loopback, link-local, private, multicast, carrier-grade NAT, metadata, and IPv6 equivalent ranges; disallow redirects; enforce host allowlists or per-endpoint administrator approval; use a short timeout, size cap, and egress firewall; revalidate after DNS resolution to mitigate rebinding.	Automated tests deny 127.0.0.1, ::1, RFC1918, link-local, metadata, redirect chains, and rebinding simulations. Staging delivery succeeds only to approved public test endpoints.

, [P0-2], [Independent release gate], [No source review can prove absence of exploitable chains. Before launch, commission an external authenticated web/API assessment against staging, plus a defined remediation/retest gate.], [Signed assessment scope, findings register, retest evidence, explicit risk acceptance for any deferred issue.]), [P0-3], [Operational recovery proof], [Local archive verification is now working, but an actual controlled restore rehearsal and at least one independent encrypted

offsite destination must be completed before storing customer data.], [Documented restore exercise with measured RTO/RPO, owner sign-off, and tested cloud destination.]), [P0-4], [Launch configuration verification], [Confirm production DNS, Cloudflare Full (strict), certificate hostname/expiry, WAF/bot policy, authenticated origin pull decision, Stripe live webhook, email delivery, and legal/privacy workflows in a pre-launch checklist.], [Completed signed checklist and successful transaction/email/webhook smoke tests using non-customer test data.]))

3.2 P1 — complete during controlled launch readiness

Priority	Workstream	Required outcome
P1-1	Secure SDLC / CI	Add protected-branch review, CI typecheck/test/security suite, dependency and secret scanning, SBOM generation, artifact retention, and release approval records. OWASP recommends security activities throughout requirements, design, implementation, verification, operations, and supply chain—not as a separate late phase. [3]

, [P1-2], [Threat modeling], [Create a versioned threat model for login/MFA, payments, file upload/download, admin destructive operations, customer collaboration, webhooks, Cloudflare/origin trust, backups, and update channels. Map abuse cases to tests.]), [P1-3], [Outbound integration governance], [Define endpoint ownership, secret rotation, HMAC requirements, replay/idempotency, content-type validation, payload minimization, delivery retention, and emergency disable procedures for all inbound/outbound webhooks.]), [P1-4], [Content/editor safety], [Server-sanitize administrator-authored email HTML using an allowlist and render previews in a sandboxed isolated document. Current CSP reduces browser execution exposure, but sanitization limits accidental or malicious active content in previews and outbound messages.]), [P1-5], [Monitoring and incident response], [Route high-confidence alerts to a monitored channel, define severity/ownership/response SLAs, retain security logs appropriately, and exercise a compromised-account and exposed-webhook-secret runbook.]), [P1-6], [Certificate governance], [Maintain a certificate inventory with issuer, SANs, key type, install date, expiry, renewal method, and owner. Cloudflare does not send Origin CA expiry notifications, so own monitoring is required when that option is used. [5]]))

3.3 P2 and P3 — resilience and maturity

P2 should cover rate-limit/load testing, storage quota/ZIP/export pressure testing, privacy data-retention validation, periodic access reviews, SSO role-mapping review, immutable backup testing, and a customer-support recovery process. P3 should establish quarterly access reviews, annual third-party assessment, continuous security training, tabletop exercises, and SAMM-aligned measurable maturity targets. SAMM is designed as a risk-driven, iterative framework for improving a software-security program. [4]

4 API and webhook security requirements

Every API object lookup must continue to perform authorization at the server—not only hide UI controls. For every object-bearing request, create negative tests for another customer, a non-owner workspace

member, an inactive/trashed account, an unpaid order, a staff account, and an administrator. This directly addresses OWASP's warning that identifiers create a broad broken-object-authorization attack surface. [2] Webhook controls require additional rigor because an outbound receiver becomes part of the security boundary. The launch baseline should be: endpoint allowlisting; SSRF-safe URL validation; signed payloads; timestamp/nonce/replay protection at receiving systems; explicit retry limits; delivery idempotency keys; redacted delivery logs; DNS/IP revalidation; no automatic redirect follow; bounded request/response size; and independently controlled egress. Do not include credentials, encryption keys, full customer documents, or unnecessary PII in webhook payloads.

5 Secure SDLC operating model

SDLC phase	Minimum ReadyPackets practice
Requirements	Record security/privacy requirements, data classification, abuse cases, acceptance tests, and accountable owner for each significant feature.

, [Design], [Perform lightweight threat modeling before identity, payment, file, webhook, backup, or integration changes. Design trust boundaries and failure modes.]), [Implementation], [Use typed validation, server-side authorization, security-reviewed libraries, secret-safe configuration, code review, and default-deny decisions.]), [Verification], [Run unit/integration tests, SAST, dependency/secret scanning, security regression suite, DAST in staging, and manual authorization/webhook tests.]), [Release], [Create an SBOM, pin/record the immutable commit, capture test evidence, verify migrations/rollback, and obtain accountable approval.]), [Operations], [Monitor health, backups, certificate expiry, webhook failures, fraud/rate anomalies, and high-severity security alerts; test incident response and recovery.]))

OWASP's Developer Guide explicitly recommends incorporating security activities inside the existing SDLC, with threat modeling, verification, supply-chain tracking, and automated SAST/DAST/IAST practices as appropriate. [3]

6 Decision gates and next actions

The recommended sequence is: (1) remediate and test outbound webhook SSRF; (2) configure and test an independent encrypted cloud backup target; (3) run a controlled restore rehearsal; (4) complete staging smoke tests for Stripe, email, SSO, upload, customer workflows, and admin recovery; (5) complete an external authenticated assessment; and (6) approve a launch checklist with named owners and rollback triggers.

The next 48 hours should prioritize **safety over feature breadth**. Defer non-essential feature work until P0 controls are complete. A limited invite-only beta is possible only if the owner accepts the remaining risks in writing and if high-risk outbound integrations are disabled or strictly allowlisted.

7 References

[1] OWASP, **OWASP Top 10:2025**. <https://owasp.org/Top10/2025/en/>

[2] OWASP, **OWASP Top 10 API Security Risks – 2023**. <https://owasp.org/API-Security/editions/2023/en/0x11-t10/>

- [3] OWASP Developer Guide, **Secure development and integration**. <https://devguide.owasp.org/en/02-foundations/02-secure-development/>
- [4] OWASP, **Software Assurance Maturity Model (SAMM)**. <https://owasp.org/www-project-samm/>
- [5] Cloudflare, **Cloudflare Origin CA**. <https://developers.cloudflare.com/ssl/origin-configuration/origin-ca/>
- [6] Cloudflare, **Full (strict)**. <https://developers.cloudflare.com/ssl/origin-configuration/ssl-modes/full-strict/>
- [7] Cloudflare, **Create Origin CA Certificate API**. https://developers.cloudflare.com/api/resources/origin_ca_certificates/methods/create/